

Alvo: http://localhost:3000/
Data: 15/05/2026 11:17
Total de findings: 42

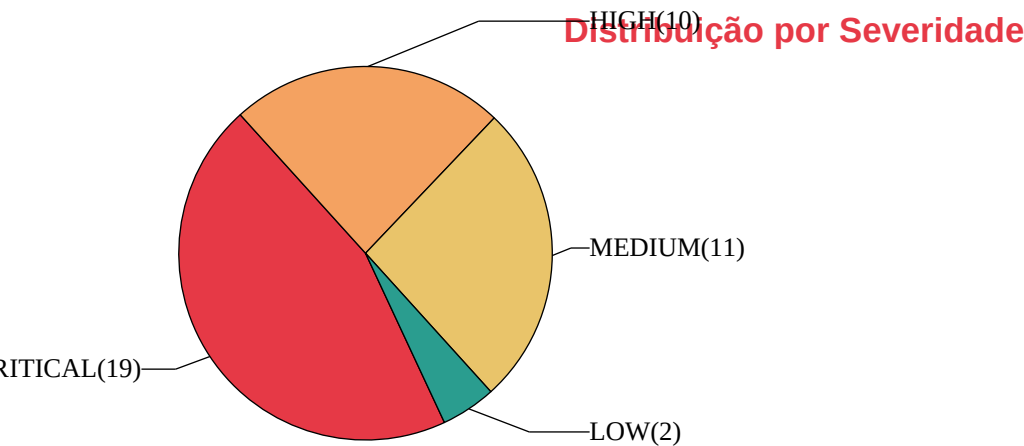
Security Score



CRÍTICO — Ação imediata

Resumo Executivo

Severidade	Qtd	Prazo
[CRITICAL]	19	Imediato
[HIGH]	10	≤ 7 dias
[MEDIUM]	11	≤ 30 dias
[LOW]	2	Próx. ciclo



■ Insights da IA

- ■ 19 finding(s) CRÍTICO(s) — requerem atenção imediata antes de qualquer deploy.
- ■ SSRF detectado — possível acesso a infraestrutura interna ou metadata de cloud.
- ■ Issues recorrentes entre scans: Ausência de rate limiting em endpoint de autenticação, SSRF, Keyword sensível: 'root' — padrão sistêmico.

Issues mais recorrentes (memória histórica)

Issue	Ocorrências
Ausência de rate limiting em endpoint de autenticação	173
SSRF	168
Keyword sensível: 'root'	52
Keyword sensível: 'password'	44
Keyword sensível: 'test'	44
Keyword sensível: 'token'	39
Keyword sensível: 'debug'	26
Path sensível exposto: /.env	20

■ Vulnerabilidades Críticas e Altas

1. [CRITICAL] Path sensível exposto: /backup.sql

URL: <http://localhost:3000/backup.sql>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

2. [CRITICAL] Path sensível exposto: /dump.sql

URL: <http://localhost:3000/dump.sql>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

3. [HIGH] SSRF

URL: <http://localhost:3000/>

CVSS estimado: 8.6

Impacto: Acesso a serviços internos e metadata de cloud.

Recomendação: Whitelist de URLs permitidas. Bloquear ranges privados.

Evidência: <http://127.0.0.1>

4. [HIGH] SSRF

URL: <http://localhost:3000/>

CVSS estimado: 8.6

Impacto: Acesso a serviços internos e metadata de cloud.

Recomendação: Whitelist de URLs permitidas. Bloquear ranges privados.

Evidência: <http://127.0.0.1>

5. [HIGH] SSRF

URL: <http://localhost:3000/>

CVSS estimado: 8.6

Impacto: Acesso a serviços internos e metadata de cloud.

Recomendação: Whitelist de URLs permitidas. Bloquear ranges privados.

Evidência: <http://127.0.0.1>

6. [HIGH] SSRF

URL: <http://localhost:3000/>

CVSS estimado: 8.6

Impacto: Acesso a serviços internos e metadata de cloud.

Recomendação: Whitelist de URLs permitidas. Bloquear ranges privados.

Evidência: <http://127.0.0.1>

7. [HIGH] SSRF

URL: <http://localhost:3000/>

CVSS estimado: 8.6

Impacto: Acesso a serviços internos e metadata de cloud.

Recomendação: Whitelist de URLs permitidas. Bloquear ranges privados.

Evidência: <http://127.0.0.1>

8. [HIGH] SSRF

URL: <http://localhost:3000/>

CVSS estimado: 8.6

Impacto: Acesso a serviços internos e metadata de cloud.

Recomendação: Whitelist de URLs permitidas. Bloquear ranges privados.

Evidência: <http://127.0.0.1>

9. [CRITICAL] Keyword sensível: 'password='

URL: <http://localhost:3000/main.js>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

10. [CRITICAL] Path sensível exposto: /debug

URL: <http://localhost:3000/debug>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

11. [HIGH] Keyword sensível: 'token'

URL: <http://localhost:3000/main.js>

CVSS estimado: 7.5

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

12. [HIGH] Keyword sensível: 'root'

URL: <http://localhost:3000/polyfills.js>

CVSS estimado: 7.5

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

13. [HIGH] Keyword sensível: 'api_key'

URL: <http://localhost:3000/scripts.js>

CVSS estimado: 7.5

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

14. [HIGH] Keyword sensível: 'root'

URL: <http://localhost:3000/>

CVSS estimado: 7.5

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

15. [CRITICAL] Path sensível exposto: /.env

URL: <http://localhost:3000/.env>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

16. [CRITICAL] Path sensível exposto: /.git/config

URL: <http://localhost:3000/.git/config>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

17. [CRITICAL] Path sensível exposto: /.git/HEAD

URL: <http://localhost:3000/.git/HEAD>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

18. [CRITICAL] Path sensível exposto: /config.php

URL: <http://localhost:3000/config.php>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

19. [CRITICAL] Path sensível exposto: /wp-config.php

URL: <http://localhost:3000/wp-config.php>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

20. [CRITICAL] Path sensível exposto: /.htaccess

URL: <http://localhost:3000/.htaccess>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

21. [CRITICAL] Path sensível exposto: /server-status

URL: <http://localhost:3000/server-status>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

22. [CRITICAL] Path sensível exposto: /phpinfo.php

URL: <http://localhost:3000/phpinfo.php>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

23. [CRITICAL] Path sensível exposto: /info.php

URL: <http://localhost:3000/info.php>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

24. [CRITICAL] Path sensível exposto: /actuator

URL: <http://localhost:3000/actuator>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

25. [CRITICAL] Path sensível exposto: /actuator/env

URL: <http://localhost:3000/actuator/env>

CVSS estimado: 9.0

Impacto: Avaliar impacto conforme contexto da aplicação.

Recomendação: Revisar e corrigir conforme contexto.

■ Pipeline 4 — Resultados do Ataque

- Banco de dados comprometido — versão: 69.5241935484. Dump de dados sensíveis pode ser possível.
- 5 arquivo(s) de configuração da aplicação acessados — possível exposição de credenciais.
- Arquivos Confidenciais/Métricas acessados: 5 arquivo(s).

Métrica	Resultado
Versão do banco extraída	69.5241935484
Tabelas enumeradas	40
Registros vazados	0
Auth bypass por SQLi	0
XSS confirmados	0
DOM XSS potencial	0
Arquivos lidos via LFI	0
Configs expostos	5
Log Poisoning	Não
Credenciais válidas	0
Usuários enumerados	0

■ Recomendações Gerais

- Implementar WAF na frente da aplicação.
- Habilitar todos os security headers (CSP, HSTS, X-Frame-Options, etc.).
- Remover secrets do frontend. Usar variáveis de ambiente e secret managers.
 - Adotar prepared statements em todas as queries SQL.
 - Implementar rate limiting em endpoints de autenticação.
 - Manter dependências atualizadas com patches de segurança.
- Configurar monitoramento de logs com alertas para padrões de ataque.
- Realizar pentest manual focado nos findings críticos deste relatório.